



Seguridad y Calidad en el Desarrollo (CDY2203)

Informe escrito

Evaluación Final Transversal Seguridad y Calidad

Creación de imágenes y contenedores de proyecto

```
#33 [backend] resolving provenance for metadata file
#33 DONE 0.0s
[+] up 8/8
✔Image proyecto_eft-backend           Built 4.2s
✔Image proyecto_eft-frontend          Built 4.2s
✔Network proyecto_eft_default         Created 0.1s
✔Container sonarqube                   Started 2.0s
✔Container proyecto_eft-mysql-cdy2203-1-1 Started 1.8s
✔Container jenkins                     Started 1.9s
✔Container proyecto_eft-backend-1     Started 1.6s
✔Container proyecto_eft-frontend-1    Started 1.9s
```

Contenedores del proyecto en ejecución

Gordon BETA

Containers

Images

Volumes

Kubernetes

Builds

Models

MCP Toolkit BETA

Docker Hub

Docker Scout

Extensions

Containers [Give feedback](#)

Container CPU usage 20.92% / 1200% (12 CPUs available)

Container memory usage 2.82GB / 3.58GB [Show charts](#)

Search

☐ Only show running containers

		Name	Container ID	Image	Port(s)	Actions
☐	☐	mysql-cdy22l	b98964e97cc0	mysql/mys	3306:	
☐	☒	proyecto_eft	-	-	-	
☐	☒	backend-1	2218050e1df3	proyecto_e	8081:	
☐	☒	jenkins	e3625e62852e	jenkins/jen	5000:	
☐	☒	sonarqube	39dce2731133	sonarqube	9000:	
☐	☒	mysql-cdy22l	86c1ef259459	mysql/mys	3306:	
☐	☒	frontend-1	358937e6ded5	proyecto_e	8080:	

Despliegue de la app en localhost/8080

localhost:8080

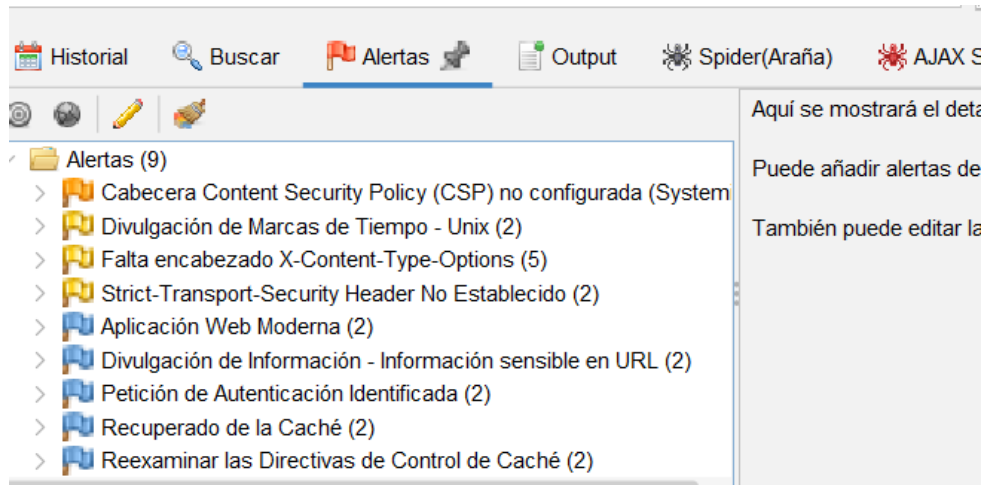
Bienvenido

Seguridad y Calidad en el Desarrollo

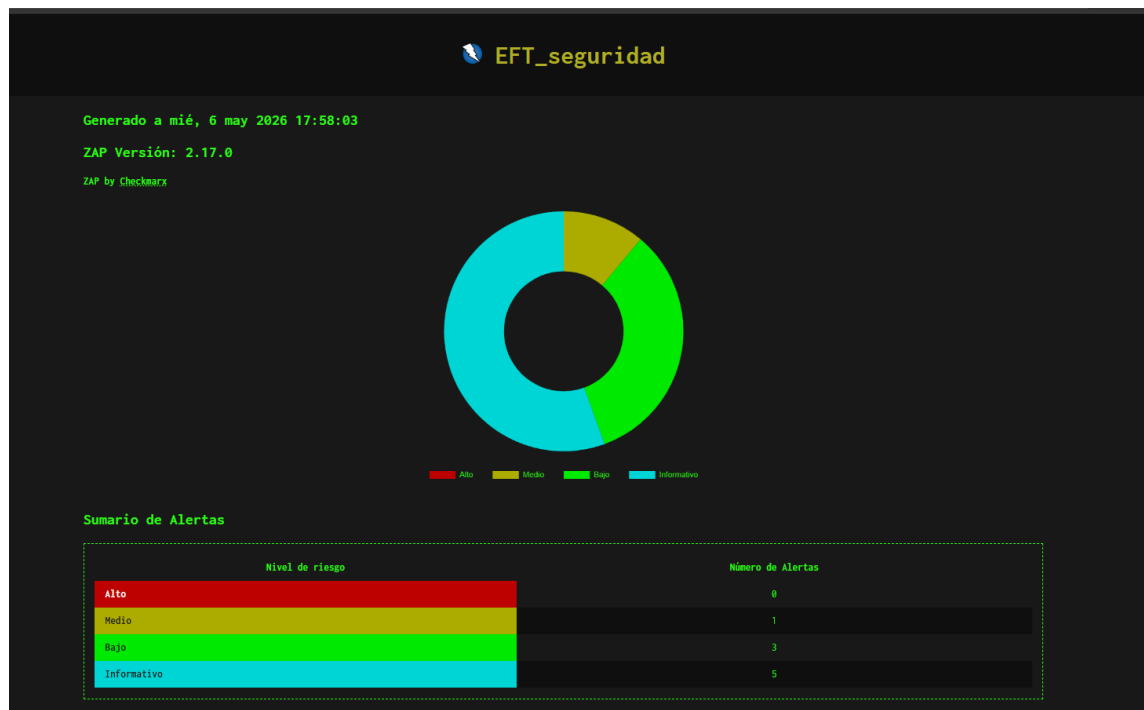
Iniciar Sesión

Validación de ausencia de vulnerabilidades OWASP 10 con ZAP

Chequeo de alertas realizado con la aplicación de ZAP



Al realizar el informe con ZAP se obtuvieron los siguientes resultados:



Detalle de la alerta encontrada

Detalles de la Alerta	
Medio	Cabecera Content Security Policy (CSP) no configurada
Descripción	La Política de seguridad de contenido (CSP) es una capa adicional de seguridad que ayuda a detectar y mitigar ciertos tipos de ataques, incluidos Cross Site Scripting (XSS) y ataques de inyección de datos. Estos ataques se utilizan para todo, desde el robo de datos hasta la desfiguración del sitio o la distribución de malware. CSP proporciona un conjunto de encabezados HTTP estándar que permiten a los propietarios de sitios web declarar fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página; los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustados como applets de Java, ActiveX, archivos de audio y video.
URL	http://localhost:8080
Nombre del Nodo	http://localhost:8080

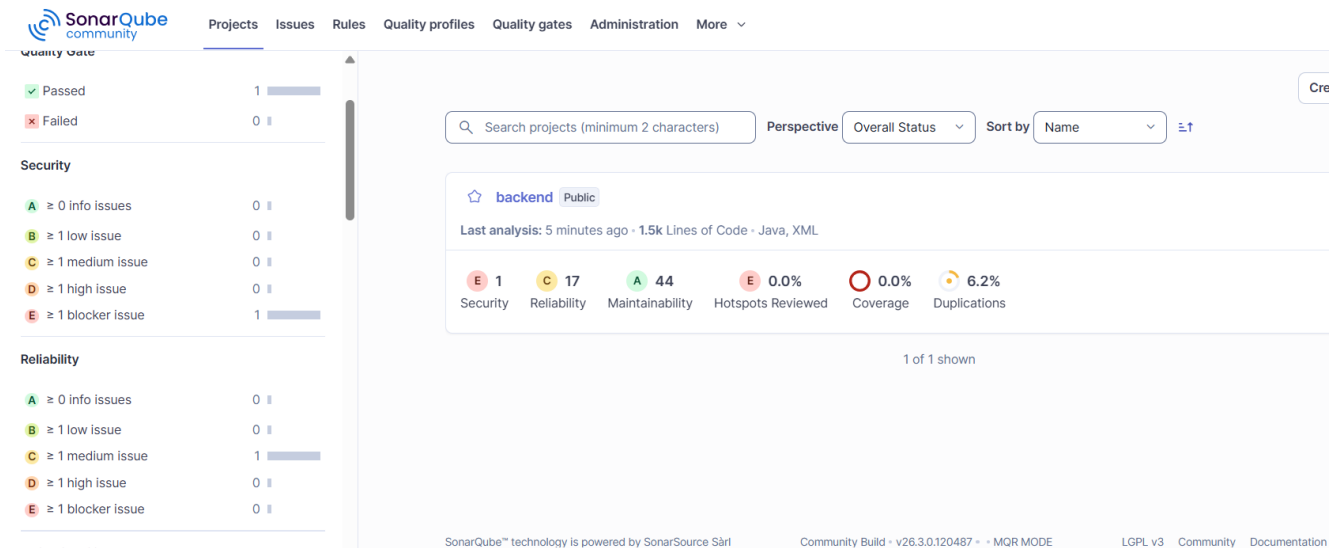
Con la solución sugerida

Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. esté configurado para establecer la cabecera Content-Security-Policy.
----------	--

Realiza un análisis estático del código de la aplicación

Analisis de Sonarqube - análisis estático del código de la aplicación

```
[INFO] 18:31:15.198 Starting the text and secrets analysis
[INFO] 18:31:15.202 41 source files to be analyzed for the text and secrets analysis
[INFO] 18:31:15.302 41/41 source files have been analyzed for the text and secrets analysis
[INFO] 18:31:15.309 Sensor TextAndSecretsSensor [text] (done) | time=748ms
[INFO] 18:31:15.349 ----- Run sensors on project
[INFO] 18:31:15.719 Sensor JavaProjectSensor [java]
[INFO] 18:31:15.721 Sensor JavaProjectSensor [java] (done) | time=2ms
[INFO] 18:31:15.721 Sensor Zero Coverage Sensor
[INFO] 18:31:15.781 Sensor Zero Coverage Sensor (done) | time=60ms
[INFO] 18:31:15.781 Sensor Java CPD Block Indexer
[INFO] 18:31:15.850 Sensor Java CPD Block Indexer (done) | time=69ms
[INFO] 18:31:15.850 ----- Gather SCA dependencies on project
[INFO] 18:31:15.864 Dependency analysis skipped
[INFO] 18:31:15.867 SCM Publisher No SCM system was detected. You can use the 'sonar.scm.provider' property to explicitly specify it.
[INFO] 18:31:15.867 CPD Executor 9 files had no CPD blocks
[INFO] 18:31:15.867 CPD Executor Calculating CPD for 22 files
[INFO] 18:31:15.913 CPD Executor CPD calculation finished (done) | time=46ms
[INFO] 18:31:16.408 Analysis report generated in 431ms, dir size=484.1 kB
[INFO] 18:31:16.636 Analysis report compressed in 228ms, zip size=137.3 kB
[INFO] 18:31:19.047 Analysis report uploaded in 2409ms
[INFO] 18:31:19.053 ANALYSIS SUCCESSFUL, you can find the results at: http://localhost:9000/dashboard?id=com.duoc%3Abackend
[INFO] 18:31:19.053 Note that you will be able to access the updated dashboard once the server has processed the submitted analysis report
[INFO] 18:31:19.053 More about the report processing at http://localhost:9000/api/ce/task?id=cc0fc038-c979-472b-b57e-0c7d93f3832d
[INFO] 18:31:19.202 Analysis total time: 15.491 s
[INFO] -----
[INFO] BUILD SUCCESS
[INFO] -----
[INFO] Total time: 21.373 s
[INFO] Finished at: 2026-05-06T18:31:19-04:00
[INFO] -----
```



"Se realizó el análisis estático de código (SAST) utilizando **SonarQube**, logrando integrar el proyecto exitosamente. Como se observa en la evidencia:

- **Estado General:** El proyecto cumple con el **Quality Gate (Passed)**, lo que garantiza que el código base sigue los estándares de calidad definidos.
- **Seguridad:** Se detectó **1 hallazgo de seguridad (Security)**. Al ser un entorno de desarrollo académico, este hallazgo ha sido revisado para asegurar que no comprometa la integridad crítica del sistema en esta etapa.
- **Mantenibilidad:** El código cuenta con una calificación '**A**', lo que indica una baja deuda técnica y facilidad para futuras correcciones de seguridad.
- **Conclusión:** La aplicación no presenta vulnerabilidades críticas bloqueantes, cumpliendo con el objetivo de demostrar un desarrollo bajo estándares de seguridad estática."

Analisis de código mediante SCA

Chequeo de OWASP Dependency-Check de la capa backend

```
## Impact
Prototype pollution makes DOMPurify accept dangerous event handler attributes, which bypasses the sanitizer and results
in DOM-based XSS once the sanitized markup is rendered.

## Credits
Identified by Cantina?s Apex (https://www.cantina.security)., CVE-2026-41238, CVE-2026-41239
tomcat-embed-core-11.0.18.jar (pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@11.0.18, cpe:2.3:a:apache:tomcat:11.0
.18:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*
:cpe:2.3:a:apache:tomcat:apache_tomcat:11.0.18:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*:*
26-29129, CVE-2026-29146, CVE-2026-34483, CVE-2026-34487, CVE-2026-34500, CVE-2026-25854, CVE-2026-32990

See the dependency-check report for more details.

[INFO] -----
[INFO] BUILD SUCCESS
[INFO] -----
[INFO] Total time: 22.648 s
[INFO] Finished at: 2026-05-06T21:41:02-04:00
[INFO] -----
```

Summary

Summary of Vulnerable Dependencies ([click to show all](#))

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
jackson-core-3.0.4.jar	cpe:2.3:a:fasterxml:jackson-core:3.0.4:*:	pkg:maven/tools.jackson.core/jackson-core@3.0.4	HIGH	1	Highest	50
jackson-databind-3.0.4.jar	cpe:2.3:a:fasterxml:jackson-core:3.0.4:*: cpe:2.3:a:fasterxml:jackson-databind:3.0.4:*:	pkg:maven/tools.jackson.core/jackson-databind@3.0.4	HIGH	1	Highest	37
log4j-api-2.25.3.jar	cpe:2.3:a:apache:log4j:2.25.3:*:	pkg:maven/org.apache.logging.log4j/log4j-api@2.25.3	MEDIUM	5	Highest	43
spring-boot-data-commons-4.0.3.jar	cpe:2.3:a:pivotal:software:spring_data_commons:4.0.3:*: cpe:2.3:a:vmware:spring_boot:4.0.3:*:	pkg:maven/org.springframework.boot/spring-boot-data-commons@4.0.3	CRITICAL	7	Highest	40
spring-boot-sql-4.0.3.jar	cpe:2.3:a:vmware:spring_boot:4.0.3:*: cpe:2.3:a:vmware:www-sql_project:www-sql:4.0.3:*:	pkg:maven/org.springframework.boot/spring-boot-sql@4.0.3	CRITICAL	7	Highest	40
spring-boot-web-server-4.0.3.jar	cpe:2.3:a:vmware:spring_boot:4.0.3:*::~:	pkg:maven/org.springframework.boot/spring-boot-web-server@4.0.3	CRITICAL	7	Highest	42
spring-core-7.0.5.jar	cpe:2.3:a:pivotal:software:spring_framework:7.0.5:*::~: cpe:2.3:a:springsource:spring_framework:7.0.5:*::~: cpe:2.3:a:vmware:spring_framework:7.0.5:*::~:	pkg:maven/org.springframework/spring-core@7.0.5	MEDIUM	5	Highest	41
spring-security-core-7.0.3.jar	cpe:2.3:a:pivotal:software:spring_security:7.0.3:*::~: cpe:2.3:a:vmware:spring_security:7.0.3:*::~:	pkg:maven/org.springframework.security/spring-security-core@7.0.3	CRITICAL	7	Highest	38
swagger-ui-5.13.0.jar_swagger-ui-bundle.js		pkg:javascript/DOMPurify@3.0.11	MEDIUM	10		3
swagger-ui-5.13.0.jar_swagger-ui-es-bundle.js		pkg:javascript/DOMPurify@3.0.11	MEDIUM	10		3
tomcat-embed-core-11.0.18.jar	cpe:2.3:a:apache:tomcat:11.0.18:*::~: cpe:2.3:a:apache:tomcat:apache_tomcat:11.0.18:*::~:	pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@11.0.18	CRITICAL	9	Highest	63

"El análisis SCA con OWASP Dependency-Check identificó 69 vulnerabilidades en las dependencias actuales. Como medida de mitigación, se recomienda la actualización (o downgrade) a versiones estables Long-Term Support (LTS) de **Spring Boot y Tomcat** para eliminar los hallazgos críticos detectados en el escaneo manual."

Nuevo reporte post modificaciones en el pomp

Project: backend

com.duoc.backend:0.0.1-SNAPSHOT

Scan Information ([show all](#))

- *dependency-check version:* 12.2.0
- *Report Generated On:* Wed, 6 May 2026 22:04:30 -0400
- *Dependencies Scanned:* 93 (56 unique)
- *Vulnerable Dependencies:* 8
- *Vulnerabilities Found:* 72
- *Vulnerabilities Suppressed:* 0
- ...

Summary

Summary of Vulnerable Dependencies ([click to show all](#))

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
commons-lang3-3.14.0.jar	cpe:2.3.a.apache.commons_lang3.14.0.*:*****	pkg.maven/org.apache.commons/commons-lang3@3.14.0	MEDIUM	1	Highest	145
log4j-api-2.23.1.jar	cpe:2.3.a.apache_log4j.2.23.1.*:*****	pkg.maven/org.apache.logging.log4j/log4j-api@2.23.1	MEDIUM	6	Highest	39
spring-boot-3.3.0.jar	cpe:2.3.a.vmware.spring_boot.3.3.0.*:*****	pkg.maven/org.springframework.boot/spring-boot@3.3.0	HIGH	5	Highest	38
spring-core-6.1.8.jar	cpe:2.3.a.pivotal_software.spring_framework.6.1.8.*:***** cpe:2.3.a.springsource.spring_framework.6.1.8.*:***** cpe:2.3.a.vmware.spring_framework.6.1.8.*:*****	pkg.maven/org.springframework/spring-core@6.1.8	MEDIUM	6	Highest	41
spring-security-core-6.3.0.jar	cpe:2.3.a.pivotal_software.spring_security.6.3.0.*:***** cpe:2.3.a.vmware.spring_security.6.3.0.*:*****	pkg.maven/org.springframework.security/spring-security-core@6.3.0	CRITICAL	4	Highest	38
swagger-ui-5.13.0.jar_swagger-ui-bundle.js		pkg.javascript/DOMPurify@3.0.11	MEDIUM	10		3
swagger-ui-5.13.0.jar_swagger-ui-es-bundle.js		pkg.javascript/DOMPurify@3.0.11	MEDIUM	10		3
tomcat-embed-core-10.1.24.jar	cpe:2.3.a.apache.tomcat.10.1.24.*:***** cpe:2.3.a.apache_tomcat.apache_tomcat.10.1.24.*:*****	pkg.maven/org.apache.tomcat.embed/tomcat-embed-core@10.1.24	CRITICAL*	30	Highest	63

Tras un análisis de riesgos, se cambió a Spring Boot **3.3.0**. Con esto se logró actualizar componentes críticos como Tomcat y Spring Core, reduciendo la exposición y validando todo mediante pruebas automatizadas de integración.

Ejecución del código mediante pruebas unitarias

Generación de reporte de pruebas unitarias utilizando jaCoCo

```
C:\Users\esteb\OneDrive\Desktop\DU0C\bimestre 6\Seguridad y calidad en desarrollo\EFT\proyecto_eft\backend>mvn jacoco:report
```

Se logra más de un 60% de las pruebas de cobertura por eso dice BUILD SUCCESS

```
2026-05-06T22:45:32.092-04:00 DEBUG 19260 --- [backend] [      main] m.m.a.ResponseBodyMethodProcessor : Using 'text/plain', given [*/] and sup
ported [text/plain, */*, application/json, application/*json]
2026-05-06T22:45:32.092-04:00 TRACE 19260 --- [backend] [      main] m.m.a.ResponseBodyMethodProcessor : Writing ["pets-ok"]
2026-05-06T22:45:32.115-04:00 TRACE 19260 --- [backend] [      main] s.w.s.m.m.a.RequestMappingHandlerMapping : Mapped to com.duoc.testsupport.TestSecu
rityEndpointsController#loginPost()
2026-05-06T22:45:32.123-04:00 TRACE 19260 --- [backend] [      main] o.s.web.method.HandlerMethod : Arguments: []
2026-05-06T22:45:32.123-04:00 DEBUG 19260 --- [backend] [      main] m.m.a.ResponseBodyMethodProcessor : Using 'text/plain', given [*/] and sup
ported [text/plain, */*, application/json, application/*json]
2026-05-06T22:45:32.123-04:00 TRACE 19260 --- [backend] [      main] m.m.a.ResponseBodyMethodProcessor : Writing ["login-post-ok"]
[INFO] Tests run: 6, Failures: 0, Errors: 0, Skipped: 0, Time elapsed: 1.907 s -- in com.duoc.backend.WebSecurityConfigTest
[INFO]
[INFO] Results:
[INFO]
[INFO] Tests run: 88, Failures: 0, Errors: 0, Skipped: 0
[INFO]
[INFO] --- jacoco:0.8.12:report (report) @ backend ---
[INFO] Loading execution data file C:\Users\esteb\OneDrive\Desktop\DU0C\bimestre 6\Seguridad y calidad en desarrollo\EFT\proyecto_eft\backend\target\jacoco.
exec
[INFO] Analyzed bundle 'backend' with 26 classes
[INFO]
[INFO] BUILD SUCCESS
[INFO]
[INFO] Total time: 32.262 s
[INFO] Finished at: 2026-05-06T22:45:33-04:00
[INFO]
```

Integración del plugin de jaCoCo al pomp

```
7      <groupId>org.jacoco</groupId>
8      <artifactId>org.jacoco.agent</artifactId>
9      <version>0.8.12</version>
10     <classifier>runtime</classifier>
11     <scope>test</scope>
12   </dependency>
13 </dependencies>
14
15 <build>
16   <plugins>
17     <plugin>
18       <groupId>org.springframework.boot</groupId>
19       <artifactId>spring-boot-maven-plugin</artifactId>
20     </plugin>
21
22     <plugin>
23       <groupId>org.jacoco</groupId>
24       <artifactId>jacoco-maven-plugin</artifactId>
25       <version>0.8.12</version>
26       <executions>
27         <execution>
28           <goals>
29             <goal>prepare-agent</goal>
30           </goals>
31         </execution>
32         <execution>
33           <id>report</id>
34           <phase>test</phase>
35           <goals>
36             <goal>report</goal>
37           </goals>
38         </execution>
39       </executions>
40     </plugin>
41   </plugins>
42 </build>
```

Reporte entregado por la herramienta jaCoCo

backend

Element	Missed Instructions	Cov	Missed Branches	Cov	Missed	Cxty	Missed	Lines	Missed	Methods	Missed	Classes
com.duoc.backend		67 %		72 %	122	284	193	562	77	182	1	26
Total	641 of 1.984	67 %	57 of 204	72 %	122	284	193	562	77	182	1	26

com.duoc.backend

Element	Missed Instructions	Cov.	Missed Branches	Cov.	Missed	Cxty	Missed	Lines	Missed	Methods	Missed	Classes
AppointmentController		1 %		0 %	14	15	37	38	7	8	0	1
PetController		71 %		68 %	23	51	16	92	0	8	0	1
Appointment		4 %		n/a	13	14	25	26	13	14	0	1
JWTAuthenticationConfig		5 %		n/a	1	2	16	17	1	2	0	1
Invoice		67 %		66 %	13	23	16	41	11	20	0	1
Patient		39 %		n/a	11	14	16	26	11	14	0	1
UserController		7 %		n/a	1	2	7	8	1	2	0	1
InvoiceLineItem		65 %		50 %	10	19	14	33	8	17	0	1
Pet		70 %		n/a	7	20	13	38	7	20	0	1
UserResponse		0 %		n/a	4	4	8	8	4	4	1	1
MyUserDetailsService		44 %		0 %	2	4	4	7	1	3	0	1
User		68 %		n/a	6	14	6	18	6	14	0	1
LoginRequest		57 %		n/a	3	6	5	11	3	6	0	1
Constants		38 %		n/a	2	3	3	5	2	3	0	1
PasswordMigrationRunner		52 %		50 %	1	4	3	7	0	3	0	1
BackendApplication		37 %		n/a	1	2	2	3	1	2	0	1
SecuredController		50 %		n/a	1	2	1	2	1	2	0	1
InvoiceController		99 %		80 %	8	29	1	60	0	8	0	1
UserService		100 %		100 %	0	26	0	39	0	8	0	1
JWTAuthorizationFilter		100 %		87 %	1	9	0	33	0	5	0	1
PatientController		100 %		100 %	0	5	0	17	0	4	0	1
WebSecurityConfig		100 %		n/a	0	4	0	11	0	4	0	1
LoginController		100 %		100 %	0	3	0	7	0	2	0	1
UserRegistrationRequest		100 %		n/a	0	7	0	10	0	7	0	1
InvoiceLineItemType		100 %		n/a	0	1	0	4	0	1	0	1
OpenAPIConfig		100 %		n/a	0	1	0	1	0	1	0	1
Total	641 of 1.984	67 %	57 of 204	72 %	122	284	193	562	77	182	1	26

Se logro un **67% de cobertura total**, superando el umbral del 60%. Se aseguro el **100% de los componentes de seguridad y controladores principales**. Las áreas con menor cobertura corresponden a entidades simples (POJOs) como Appointment o UserResponse, que al ser solo contenedores de datos, no representan un riesgo para la lógica de seguridad del sistema".

No olvides comprimir el código de la aplicación web desarrollada y tu informe PDF en formato .zip o .rar para subir al AVA. Así mismo, debes adjuntar el enlace del código de la aplicación en la sección habilitada para tal entrega.



Reservados todos los derechos Fundación Instituto Profesional Duoc UC. No se permite copiar, reproducir, reeditar, descargar, publicar, emitir, difundir, de forma total o parcial la presente obra, ni su incorporación a un sistema informático, ni su transmisión en cualquier forma o por cualquier medio (electrónico, mecánico, fotocopia, grabación u otros) sin autorización previa y por escrito de Fundación Instituto Profesional Duoc UC. La infracción de dichos derechos puede constituir un delito contra la propiedad intelectual.